5

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad / Öğrenci No
Mehmet Emin Yılmaz · No: 235541078

Grup
Gece B

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	J-500 Component X (Mazatrol CNC kontrol firmware kütüphanesi) — *föy kaydı J-500'e uyarlanmıştır*
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1 **Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)**

1) Bileşen var mı? J-500'ün SBOM'unda/üretici bülteninde Component X'in CNC kontrolünde (Emniyet PLC'de mi, normal kumandada mı) kullanıldığı teyit edilir. **2) Sürüm etkileniyor mu?** Kurulu sürüm 2.4; CVE'nin etkilenen sürüm aralığında → etkileniyor. **3) Açık ulaşılabilir mi?** Bugünkü yapıda uzak bakım internete açık ve ağ düz → ulaşılabilir. **Sonuç:** üç şart da sağlanıyor, bu CVE bizi etkiliyor; öncelik yüksek.

2 **Üretimi hemen durdurur musunuz? Neden / neden değil?**

Hayır, hemen durdurmam: CVSS tek başına durdurma gerekçesi değildir; plansız duruş ve termin kaybı (havacılık/savunma işleri) bir risktir ve sömürü belirtisi yok. Ama aynı gün **ulaşılabilirliği keserim**: uzak bakımı kapatır, zafiyetli servise erişimi güvenlik duvarında engellerim. Sömürü şüphesi çıkarsa (Lab 6) makineyi kontrollü durdururum; yamayı planlı bakım penceresine alırım.

3 **Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?**

Önce test. Önce makine parametreleri, PLC programı ve CNC yedeği alınır, geri dönüş planı hazırlanır, yama için Mazak yetkili servisinin onayı alınır. Test ortamı: aynı Mazatrol sürümündeki yedek/test CNC veya üretici simülasyonu; yoksa planlı bakım penceresinde parçasız kuru çalışma (dry run), düşük hız ve kapılar kapalıyken. Sonuç iyi ise üretime alınır.

4 **Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?**

Yama notları ve üretici bülteni incelenir: yama Emniyet PLC'yi, kapı kilidi/E-stop/onay şalteri sinyallerini, STO veya CNC ↔ Emniyet PLC arayüzünü kapsıyorsa SRCS'i etkiler. Anlama yolları: değişiklik yönetimi (MoC) incelemesi ve emniyet parametrelerinin yama öncesi/sonrası sağlama toplamı (CRC) karşılaştırması. Etkiliyorsa kapı kilidi, E-stop, onay şalteri, hız limiti ve STO fonksiyon testleri yeniden yapılıp kaydedilir; geçmeden üretime dönülmez.

5 **Yama mümkün değilse compensating control (telafi edici önlem) ne olur?**

Uzak bakımı varsayılan kapalı + jump server/VPN/MFA arkasına almak; zafiyetli servise erişimi güvenlik duvarı izin listesiyle kısıtlamak (Z3→Z2 conduit); ağ izleme ve alarm; USB portlarını kilitlemek; admin/admin hesabını kaldırmak; G-kod bütünlük kontrolü; çevrimdışı yedek. Kalan risk yazılı kabul edilir ve yama için hedef tarih belirlenir.

Karar özeti: Etkileniyor → üretim durmaz, erişim kesilir → önce test → emniyet doğrulaması gerekirse tekrar → yama yoksa telafi önlemleri + risk kabulü.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur. *Not: Mimari ayrıntılar eğitim amaçlı varsayımdır; üretici dokümanıyla doğrulanmalıdır.*